
Data Protection Impact Assessment (DPIA)

Organisation: JSL Sports Technology Ltd (trading as Player Portal) **Assessor:** John Leitch, Director
Date: April 2026 **Review Date:** April 2027 (annual or when processing changes materially) **Status:** Active

1. Why a DPIA is required

Under UK GDPR Article 35 and the ICO Age Appropriate Design Code, a DPIA is mandatory when processing:

- Personal data of children on a large scale
- Special category data (e.g. medical info)
- Data used for profiling or automated decision-making

Player Portal processes all three categories. This DPIA covers the risks and mitigations.

2. Processing description

2.1 Nature of processing

Player Portal is a multi-tenant SaaS platform used by football academies to manage:

- Child player profiles (name, DOB, age group, medical info, photos)
- Parent profiles (name, email, phone, payment methods)
- Attendance records
- Progress reviews (scoring across technical/attitudinal categories)
- Communications between coaches and parents
- Payment transactions (handled by Stripe under PCI DSS)

2.2 Scope

- **Data subjects:** Children under 18 (primary), parents, coaches, admins
- **Volume (at launch):** ~200 children (Jamie Allan Academy)
- **Growth projection:** 10,000+ children within 12 months across ~50 academies
- **Geographic scope:** UK only (initially)
- **Retention:** Active enrolment + 7 years post-cancellation (FA safeguarding standard)

2.3 Context

- **Data controllers:** Each academy
- **Data processor:** JSL Sports Technology Ltd (Player Portal)
- **Relationship:** Formalised via signed Data Processing Agreement (DPA)

-
- **Third parties:** Supabase (hosting), Stripe (payments), Resend (email), Vercel (infrastructure) — all contractually bound under sub-processor agreements

2.4 Purpose

- Enable academies to run training programmes
 - Facilitate parent-coach communication
 - Process payments for classes
 - Track child progress for parental visibility
 - Comply with FA safeguarding requirements
-

3. Consultation

- Reviewed ICO Age Appropriate Design Code (all 15 standards)
 - Consulted [SOLICITOR NAME] for legal review
 - Reviewed UK DPA 2018 and UK GDPR obligations
 - Reviewed FA safeguarding guidance
-

4. Necessity and proportionality

4.1 Lawful basis (per data type)

Data category	Lawful basis	Source
Child name, DOB, age	Legitimate interest of academy + parental consent	Academy captures at registration
Parent contact info	Contract (academy engagement)	Parent registration
Medical info	Explicit consent + vital interests (emergency)	Opt-in checkbox
Photos of children	Explicit parental consent	Per-gallery consent
Progress scores	Legitimate interest (educational tracking)	Contractual provision
Payment data	Contract performance + legal obligation	Stripe handles PCI DSS

4.2 Data minimisation

- Only collect fields academies actively use
- No behavioural tracking or advertising cookies
- No cross-academy data sharing without explicit consent

- Photos uploaded only when academy explicitly enables gallery feature

4.3 Children's rights

- Right to erasure: one-click parent export + delete (implemented)
- Right to access: DSAR process documented (see Breach/DSAR Runbook)
- Right to rectification: parent portal allows edit of child details
- Right to object: parents can disable photo uploads, marketing comms

5. Risks identified

#	Risk	Likelihood	Severity	Mitigation
R1	Data breach exposing children's PII	Medium	Critical	RLS on all tables, encrypted at rest (Supabase AES-256), TLS 1.3 in transit, 2FA for admins
R2	Unauthorised coach/admin access to children outside their scope	Low	High	Org-scoped RLS policies; audit logging; periodic access review
R3	Parents accessing data of children not theirs	Low	High	parent_id FK enforced at DB + UI level
R4	Medical info leakage	Low	Critical	Encrypted at rest; only visible to authorised coaches; never in emails
R5	Photos of children used inappropriately	Low	Critical	Per-gallery consent; opt-out per photo; no public URLs
R6	Payment data compromise	Very Low	Critical	Stripe handles all card data; we never see/store it
R7	Third-party sub-processor breach	Medium	High	All sub-processors are SOC 2 / ISO 27001; contractual obligations; breach notification in hours

#	Risk	Likelihood	Severity	Mitigation
R8	Malicious academy admin exfiltrating parent list	Low	High	Audit log of all exports; IP/session tracking; contract with academy holds them liable
R9	Parent account compromise	Medium	Medium	Supabase Auth with password + magic link; email change triggers re-auth
R10	Retention beyond necessary	Medium	Medium	Automated 7-year post-cancellation purge (to be implemented); annual data audit
R11	Data subject access request (DSAR) missed	Medium	Medium	Documented 30-day runbook (see 04-breach-response-plan.md)
R12	Profiling of children for advertising	N/A	N/A	We do not run any advertising; no behavioural cookies
R13	Transfer of data outside UK	Low	High	Supabase EU-West region; Stripe Ireland entity; explicit customer consent for any US-region sub-processor

6. Measures taken

6.1 Technical

- Row-Level Security (RLS) on all Supabase tables — children's data isolated per academy
- TLS 1.3 enforced on all connections (Vercel / Supabase)
- AES-256 encryption at rest
- Feature gating: Enterprise-tier audit log available for compliance
- IP-based suspicious activity detection via Supabase
- Passwords hashed (bcrypt via Supabase Auth)
- Payment processing handled entirely by Stripe (PCI DSS Level 1)
- No customer PII ever sent to logs or analytics

6.2 Organisational

- Quarterly access review: revoke any dormant admin accounts
- All directors/contributors sign confidentiality and IP assignment
- Designated DPO (to be formally appointed once customer count crosses ~50 academies)
- Breach Response Plan documented (see 04-breach-response-plan.md)
- Safeguarding Policy documented (see 03-safeguarding-policy.md)

6.3 Contractual

- Signed DPA with every academy before data transfer
 - Sub-processor agreements with Supabase, Stripe, Resend, Vercel
 - Academy MSA requires downstream academy-level compliance (DBS checks, parental consent)
-

7. Outstanding actions

Action	Owner	Due
Register with ICO	Director	This week
Get Professional Indemnity + Cyber insurance	Director	This week
Solicitor review of all legal documents	Director	Next week
Implement automated 7-year retention purge	Engineering	Month 2
Formal DPO appointment	Director	When >50 academies
Annual DPIA review scheduled	Director	April 2027

8. Sign-off

Role	Name	Signature	Date
Director / Controller of the Processing	John Leitch	_____	_____
Reviewed by solicitor	_____	_____	_____

This DPIA is reviewed annually or upon material change to processing activities. Changes since last review: initial draft.